Plan de respuesta a incidentes

Responsables: **Encargado de ciberseguridad** (coordina), **Administrador del sistema** (contención técnica), **Dirección/Alcaldía** (decisiones), **Secretaría Municipal** (comunicación y notificaciones legales).

1. Detección

- Panel `/app/seguridad`: verificación de la cadena de auditoría (diaria automática `audit:verify` y manual), eventos `seguridad.*` (CSRF fallido, acceso denegado, error 500, login fallido).
- Alertas externas: Google Workspace (inicio de sesión sospechoso), cPanel (uso anómalo), ANCI/CSIRT.

2. Clasificación (registrar en el panel de incidentes)

Severidad	Ejemplos
Crítica	Cadena de auditoría rota; fuga de `.env`/claves; acceso no autorizado a expedientes; clave de cuenta de servicio expuesta.
Alta	Cuenta de funcionario comprometida; firma realizada sin autorización; modo mock en producción.
Media	Ráfagas de fallos de autenticación; subidas maliciosas bloqueadas repetidamente.
Baja	Errores aislados, intentos bloqueados sin impacto.

Marque **"Reportable al CSIRT Nacional"** si el incidente puede tener impacto significativo (Ley 21.663). **Plazos (A VALIDAR en la normativa vigente):** alerta temprana ≤ 3 h desde el conocimiento; segundo reporte ≤ 72 h; informe final ≤ 15 días. Registre cada hito con los botones del panel (`alerta_temprana_en`, `segundo_reporte_en`, `informe_final_en`). El reporte se realiza en la plataforma de la ANCI: https://www.anci.gob.cl

3. Contención

1. Desactive al usuario afectado (`/app/admin/usuarios`) → pierde acceso en la siguiente petición.
2. Si hay sospecha de robo de sesión: vacíe la tabla `sessions` (phpMyAdmin) → todos deben reingresar.
3. Si se expuso `APP_KEY`: rotar `APP_KEY` (invalida cookies/enlaces firmados) y la sesión.
4. Si se expuso un modo/ credencial externa: ver §5.
5. Si la cadena de auditoría está rota: **no** borre nada; exporte la tabla `audit_log` y la BD completa (evidencia), identifique el primer id roto (`audit:verify`).

4. Erradicación y recuperación

- Restaurar desde respaldo verificado (README → Respaldo y restauración); validar cadena y descifrado de archivos.
- Revisar `audit_log` desde el último registro íntegro; corregir cuentas/permisos; parchear la causa raíz.
- Re-ejecutar pruebas (`vendor/bin/phpunit`) antes de reponer el servicio si hubo cambios de código.

5. Rotación de secretos

Secreto	Procedimiento
Clave JSON de la cuenta de servicio (Gmail)	Google Cloud → Cuentas de servicio → *Claves* → crear nueva → subir JSON a `sgd_secrets/` (600) → verificar envío de prueba → **eliminar la clave anterior** en Google Cloud. Si el compromiso es grave: deshabilitar la cuenta y revocar la delegación de dominio en la Consola de administración y crear otra. Revisar en Gmail del buzón dedicado los envíos no autorizados.
`FILE_ENCRYPTION_KEYS`	Agregue una nueva clave `k2` al JSON, cambie `FILE_ENCRYPTION_KEY_ID=k2` (las claves antiguas siguen descifrando); los archivos nuevos usan `k2`. Para re-cifrar archivos antiguos, descifre y vuelva a guardar (script futuro) antes de retirar `k1`.
`AUDIT_HMAC_KEY`	Su cambio rompe la verificación de la cadena histórica: registre el último id verificado y la fecha en el acta antes de rotar; documentar como corte de cadena.

Secreto	Procedimiento
`FIRMAGOB_API_TOKEN_KEY` / **`FIRMAGOB_SECRET`**	Solicitar nuevas credenciales a Gobierno Digital; actualizar `.env`.
`CLAVEUNICA_CLIENT_SECRET`	Solicitar rotación a ClaveÚnica; actualizar `.env`.
Contraseña BD	Cambiar en cPanel y en `.env`.
`LLM_API_KEY`	Revocar y emitir una nueva en el proveedor.

6. Comunicación

- Notificar internamente a Alcaldía y Secretaría Municipal; si hubo datos personales comprometidos evaluar notificación a titulares (Ley 21.719 de protección de datos personales — A VALIDAR vigencia) y a la ANCI/CSIRT.
- No comunicar detalles técnicos explotables en canales abiertos.

7. Post-incidente

Informe final (lecciones aprendidas, causa raíz, acciones), actualización de esta guía y de `SEGURIDAD.md`, pruebas automatizadas que reproduzcan el hallazgo.